

해양수산부 소관 주요정보통신기반시설 보호지침

제1장 총 칙

제1조(목적) 이 지침은 「정보통신기반 보호법」 제10조에 따라 해양수산부장관이 관할하는 주요정보통신기반시설을 각종 전자적 침해행위로부터 보호하기 위하여 해당 주요정보통신기반시설 관리기관의 장이 준수해야 할 정보보호에 관한 사항을 정함을 목적으로 한다.

제2조(정의) ① 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. <삭제>
2. <삭제>
3. <삭제>
4. "주요정보통신기반시설 보호대책"(이하 "보호대책"이라 한다)이란 「정보통신기반 보호법」 (이하 "법"이라 한다) 제5조제1항의 규정에 따라 각 관리기관의 주요정보통신기반시설을 안전하게 보호하기 위한 관리적·물리적·기술적 대책을 포함한 관리기관별 보호대책을 말한다.
5. "주요정보통신기반시설 보호계획"(이하 "보호계획"이라 한다)이란 법 제5조제2항의 규정에 따라 관리기관으로부터 제출받은 보호대책을 종합·조정한 해양수산부 소관 주요정보통신기반시설에 관한 보호계획을 말한다.
6. "주요정보통신기반시설 관리기관"(이하 "관리기관"이라 한다)이란

법 제8조에 따라 해양수산부 장관(이하 "장관"이라 한다)이 지정 고시한 주요정보통신기반시설을 관리하는 기관 또는 업체를 말한다.

7. "업무종사자"란 주요정보통신기반시설을 관리·운용하는 업무와 관련된 임직원(계약직을 포함한다) 및 유지보수업체의 수탁업무 수행에 참여하는 종사자를 말한다.

② 이 지침에서 사용하는 용어의 정의는 제1항에서 정한 것을 제외하고는 법에서 정하는 바에 따른다.

제3조(적용범위) 이 지침은 법 제8조에 따라 장관이 지정 고시한 주요정보통신기반시설의 관리기관과 해당 주요정보통신기반시설을 관리·운용하는 업무종사자에 적용한다.

제4조(다른 규정과의 관계) 주요정보통신기반시설 관리기관의 장(이하 "관리기관의 장"이라 한다)은 주요정보통신기반시설 보호업무를 수행하면서 이 지침에서 구체적으로 정하지 않은 사항에 관해서는 다음 관련 규정 및 지침 등에 따른다.

1. 「정보통신기반 보호법」 및 같은 법 시행령
2. 「전자정부법」 및 같은 법 시행령
3. 「보안업무규정」
4. 「국가 사이버보안 기본지침」
5. 「국가사이버안전관리규정」
6. 「해양수산부 사이버보안 업무규정」
7. 해당 연도의 「주요정보통신기반시설 보호계획 수립지침」

8. 그 밖에 정보보호 관련 법령 및 지침·가이드·매뉴얼

제2장 보호체계 및 관리

제5조(정보보호책임관) ① 법 제6조제5항에 따른 해양수산부 정보보호 책임관은 해양수산부 기획조정실장으로 지정하며, 필요한 경우 해양수산부 정보화담당관은 정보보호책임관의 업무 수행을 지원한다.

② 정보보호책임관은 해양수산부 소관의 모든 주요정보통신기반시설의 보호에 관한 업무를 총괄한다.

③ 정보보호책임관은 다음 각 호의 업무를 총괄한다.

1. 주요정보통신기반시설 보호계획의 수립·시행
2. 주요정보통신기반시설의 지정 및 지정취소
3. 주요정보통신기반시설 보호지침의 제정·수정 및 보완
4. 정보보호 조직·체계의 구축·운영
5. 취약점 분석·평가 및 침해사고의 피해확산 방지와 신속한 대응을 위하여 필요한 조치
6. 필요한 예산 및 시설·장비 등 자산의 확보
7. 그 밖에 다른 법령에 규정되거나 소관 분야 주요정보통신기반시설의 보호를 위하여 장관이 지시하는 사항

제6조(정보보호책임자) ① 관리기관의 장은 소관 주요정보통신기반시설의 보호 업무를 담당하는 4급·4급상당 공무원, 5급·5급상당 공무원, 영관급장교 또는 임원급 관리·운영자를 정보보호책임자로 지정

해야 한다.

② 정보보호책임자는 다음 각 호의 업무를 수행한다.

1. 소관 주요정보통신기반시설의 보호대책의 수립·시행
2. 소관 주요정보통신기반시설 보호업무에 대한 기술적 조치 및 지원의 요청
3. 소관 주요정보통신기반시설의 취약점 분석·평가 및 조치
4. 소관 주요정보통신기반시설 보호에 필요한 조치 명령 또는 권고의 이행
5. 침해사고의 통지
6. 소관 주요정보통신기반시설의 복구 및 보호에 필요한 조치
7. 관리기관의 정보보호 조직·체계의 구축·운영에 관한 업무
8. 소관 주요정보통신기반시설의 취약점 분석·평가 및 침해사고의 피해확산 방지와 신속한 대응을 위하여 필요한 조치 업무
9. 소관 주요정보통신기반시설의 필요한 예산 및 시설·장비 등 자산의 확보에 관한 업무
10. 그 밖에 다른 법령에 규정된 주요정보통신기반시설의 보호업무에 관한 사항

③ 민간분야 주요정보통신기반시설과 관련한 해양수산부 내 소관 부서의 장은 소관 시설의 정보보호책임자가 제2항에 따른 각 호의 업무를 이행하도록 지도·점검 및 지원하여야 한다.

④ 관리기관의 장은 정보보호책임자를 지정하거나 변동사항이 발생한

경우에는 발생한 날로부터 15일 이내에 정보보호책임관에게 이를 통지해야 한다.

제7조(정보보호추진체계) ① 장관은 주요정보통신기반시설 보호와 관련된 다음 사항을 협의하기 위해 해양수산정보통신기반보호협의회(이하 "협의회"라 한다)를 구성·운영할 수 있다.

1. 주요정보통신기반시설의 지정 및 취소, 지정 범위 조정
2. 주요정보통신기반시설의 보호계획 및 보호대책 검토
3. 주요정보통신기반시설 이행점검 및 필요한 조치사항 권고
4. 그 밖에 주요정보통신기반시설 보호와 관련하여 협의가 필요한 사항 등

② 협의회의 장은 기획조정실장으로 하고, 간사는 정보화담당관으로 하며, 위원은 주요정보통신기반시설 정보보호책임자로 한다. 다만 협의회의 장이 필요하다고 인정하는 경우에는 외부 정보보호전문가를 위원으로 위촉할 수 있다.

제8조(업무종사자의 준수사항) ① 관리기관의 장은 소관 주요정보통신기반시설을 관리·운영하는 업무종사자가 다음 각 호의 사항을 준수하도록 해야 한다.

1. 주요정보통신기반시설의 보호책임에 관한 사항
2. 비밀유지 및 비밀서약에 관한 사항
3. 주요정보통신기반시설 보호 관련 법령 및 지침 등의 준수에 관한 사항

4. 보호 관련 지침 및 보호조치 위반에 따른 징계에 관한 사항

② 관리기관의 장은 해당 시설을 관리·운용하는 업무종사자가 보직이 변경되거나 퇴사하는 경우 법 제27조에 따라 소관 주요정보통신기반시설의 관리·운용에 관하여 취득한 비밀을 외부에 유출하지 않도록 주지시켜야 한다. 이 경우 관리기관의 장은 보직이 변경되거나 퇴사하는 자에 대하여 비밀유지에 관한 서약서를 작성하도록 요구할 수 있다.

제9조(보호업무 등의 위탁) 관리기관의 장은 소관 주요정보통신기반시설의 관리·운용 또는 취약점 분석·평가 등 보호에 관한 업무를 전문기관 또는 업체에 위탁하는 경우에는 해당 기관 또는 업체의 업무종사자에게 법 제27조에 따른 비밀유지의무를 준수하도록 비밀유지 서약서의 작성 요구, 업무 관련 기록·자료의 안전한 보존 및 폐기 명령 등 필요한 조치를 해야 한다.

제10조(관리기관간 협조) 관리기관의 장은 소관 주요정보통신기반시설의 보호를 위하여 해양수산부 소관 다른 관리기관과 다음 각 호의 사항에 관하여 상호 협조할 수 있다.

1. 주요정보통신기반시설의 보호와 관련된 정보의 공유
2. 침해사고 예방·대응 및 복구를 위한 상호협력 및 지원
3. 취약점 및 침해요인과 관련된 정보의 공유
4. 그 밖에 소관 주요정보통신기반시설의 보호를 위하여 상호협력이 필요한 사항

제11조(정보보호 교육·훈련) ① 관리기관의 장은 소관 주요정보통신

기반시설을 관리·운용하는 업무종사자를 대상으로 해당 시설의 보호를 위하여 필요한 교육·훈련을 연 1회 이상 실시해야 한다. 다만, 소관 주요정보통신기반시설의 보호에 관한 중요한 절차 및 방법 등의 변경이 있거나 신규로 직원을 채용한 때에는 지체 없이 필요한 교육·훈련을 실시해야 한다.

② 관리기관의 장은 외부의 정보보호 관련 전문기관에 제1항에 따른 교육·훈련을 위탁하여 실시할 수 있다.

③ 관리기관의 장은 제1항에 따른 교육·훈련을 실시하기 위하여 다음 각 호의 사항을 정해야 한다.

1. 교육·훈련의 내용 및 방법
2. 교육·훈련에 관한 기록유지 및 인사관리에 관한 사항
3. 그 밖에 교육·훈련을 위하여 필요한 사항

제3장 보호대책 수립·이행

제12조(보호대책 수립) ① 관리기관의 장은 법 제5조제1항에 따라 보호

대책을 수립하여 매년 8월 말일까지 장관에게 제출해야 한다. 다만, 민간분야 주요정보통신기반시설 관리기관의 장은 해양수산부의 소관 부서를 경유하여 장관에게 제출해야 한다.

② 보호대책에는 다음 각 호의 사항이 포함되어야 한다.

1. 소관 주요정보통신기반시설 보호의 목적 및 대상시설

2. 정보보호체계 및 관리 대책
 3. 취약점 분석·평가 및 조치 결과
 4. 침해사고 예방 대책
 5. 침해사고 대응 및 복구 대책
 6. 그 밖에 소관 주요정보통신기반시설의 보호를 위하여 필요한 사항
- ③ 장관은 필요할 경우 관리기관으로 하여금 제1항에 따른 보호대책 제출 시 취약점 분석·평가 결과를 함께 제출하도록 할 수 있다.
- ④ 장관은 취약점 분석·평가 결과 등을 고려하여 필요할 경우 관리기관의 장에게 보호대책을 보완하도록 요청할 수 있다.

제13조(보호대책 이행) ① 장관은 법 제6조 및 같은 법 시행령 제10조 제3항에 따라 정보통신기반보호위원회에서 심의·확정한 해양수산부 소관 보호계획을 관리기관에 통보해야 한다.

② 관리기관의 장은 제1항에 따라 통보받은 보호계획과 제12조에 따라 수립한 보호대책을 이행해야 한다.

제14조(이행점검) 장관은 법 제6조에 따른 보호계획을 수립하기 위해 관리기관을 대상으로 보호대책에 대한 이행점검을 실시할 수 있으며 필요시 관리기관으로 하여금 자체 이행점검 후 그 결과를 제출하도록 할 수 있다.

제15조(취약점 분석·평가) ① 관리기관의 장은 법 제9조 및 같은 법 시행령 제17조 및 제18조에 따라 소관 주요정보통신기반시설에 대한 취약점 분석·평가를 매년 실시해야 한다.

② 장관은 다음 각 호의 어느 하나에 해당하는 경우 관리기관의 장에게 주요정보통신기반시설의 취약점을 분석·평가하도록 명령할 수 있다.

1. 새로운 형태의 전자적 침해행위로부터 주요정보통신기반시설을 보호하기 위하여 필요한 경우

2. 주요정보통신기반시설에 중대한 변화가 발생하여 별도의 취약점 분석·평가가 필요한 경우

③ 관리기관의 장은 제1항 또는 제2항에 따라 취약점을 분석·평가하려는 경우에는 법 제9조제3항 및 같은 법 시행령 제18조에 따라 취약점을 분석·평가하는 전담반을 구성해야 한다.

④ 관리기관의 장은 제1항 또는 제2항에 따라 취약점을 분석·평가하려는 경우에는 다음 각 호의 1에 해당하는 기관으로 하여금 소관 주요정보통신기반시설의 취약점을 분석·평가하게 할 수 있다. 다만, 이 경우 제3항에 따른 전담반을 구성하지 않을 수 있다.

1. 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제52조에 따른 한국인터넷진흥원

2. 법 제16조에 따른 정보공유·분석센터

3. 「정보보호산업의 진흥에 관한 법률」 제23조에 따라 지정된 정보보호 전문서비스 기업

4. 「정부출연연구기관 등의 설립·운영 및 육성에 관한 법률」 제8조의 규정에 의한 한국전자통신연구원

⑤ 관리기관의 장은 제1항에도 불구하고 소관 정보통신기반시설이 주요정보통신기반시설로 새로이 지정된 경우에는 6개월 이내에 취약점 분석·평가를 실시해야 한다. 다만, 관리기관의 장은 취약점 분석·평가를 지정 후 6개월 이내에 시행하지 못할 특별한 사유가 있는 경우에는 장관의 승인을 받아 지정 후 9개월 이내에 실시해야 한다.

⑥ 관리기관의 장은 취약점 분석·평가 시 발견된 취약점에 대한 조치를 위해 점검 항목별 조치 이력 관리대장을 작성·관리해야 한다.

제16조(자체점검 및 수시점검) ① 관리기관의 장은 시행령 제17조제2

항에 따라 취약점 분석·평가가 필요하다고 판단하는 경우에는 평가를 완료한 때로부터 1년이 되지 않을 때에도 소관 주요정보통신기반시설에 대한 자체 점검을 실시할 수 있다.

② 관리기관의 장은 다음 각 호의 어느 하나에 해당하는 경우에는 수시로 점검(이하 "수시점검"이라 한다)을 실시할 수 있다.

1. 침해사고의 징후가 있는 경우
2. 시설·장비의 교체 및 보수를 한 경우
3. 침해사고에 따른 복구조치를 한 경우
4. 소관 주요정보통신기반시설의 보호에 관한 절차·방법 및 담당 인력의 변경이 있는 경우

③ 관리기관의 장은 제1항과 제2항에 따른 자체 점검 및 수시점검을 실시할 때에는 다음 각 호의 사항을 고려해야 한다.

1. 법 제9조에 따른 취약점 분석·평가 기준

2. 취약점 분석·평가의 범위 및 항목, 절차, 방법

3. 이전에 실시한 취약점 분석·평가의 결과

④ 관리기관의 장은 자체 점검 및 수시점검을 실시한 때에는 점검 기간, 대상, 방법 및 결과 등 점검에 관한 각종 사항을 기록·관리해야 한다.

제17조(보완조치) 관리기관의 장은 제15조에 따른 취약점 분석·평가 및 제16조에 따른 점검 결과를 반영하여 다음 각 호의 조치를 해야 한다.

1. 주요정보통신기반시설 보호를 위해 수립된 각종 보호조치, 절차 및 방법 등의 재검토 및 수정·보완
2. 시설·장비의 개축(改築)·보수 또는 설치
3. 그 밖에 취약점 분석·평가 또는 점검 결과를 반영한 보완 조치

제4장 주요정보통신기반시설 보호 및 침해사고 예방·대응

제18조(침해사고 예방) 관리기관의 장은 소관 주요정보통신기반시설을 보호하기 위하여 침해사고 예방대책을 수립·시행하는 경우에는 다음 각 호의 사항을 고려해야 한다.

1. 시스템·네트워크 관리 및 보호에 관한 대책
2. 정보보호시스템 설치·운용에 관한 대책
3. 전산자료에 대한 백업조치 등
4. 악성코드 방지 대책

5. 접근통제에 관한 대책

6. 그 밖에 소관 주요정보통신기반시설의 침해사고 예방을 위해 필요한 사항

제19조(정보통신망 보안관리) ① 관리기관의 장은 소관 주요정보통신기반시설 보호를 위하여 타 정보통신망과 분리·운영, 인터넷 연결이 차단된 관리자PC를 통한 시스템 관리기능 접속, 비인가 단말기 접속 차단 등의 기술적 통제수단을 마련해야 한다.

② 관리기관의 장은 소관 주요정보통신기반시설 관련 서버, 단말기, 네트워크 장비 등에 불필요한 서비스·사용자 계정 등은 제거하고 유지보수를 위한 외부업체의 원격관리를 금지해야 한다.

③ 관리기관의 장은 소관 주요정보통신기반시설 보호를 위하여 시스템별 사용자접근, 사용내역 등의 로그 자료를 1년 이상 보관하는 등 기록을 유지해야 한다.

제20조(연락체계의 구축) 관리기관의 장은 소관 주요정보통신기반시설에 대한 전자적 침해사고가 발생한 경우 신속히 대응하고 관계기관에 알리기 위해 필요한 연락체계를 구축해야 한다.

제21조(침해사고의 통지) ① 관리기관의 장은 침해사고가 발생하여 소관 주요정보통신기반시설이 교란·마비 또는 파괴된 사실을 인지한 때에는 법 제13조제1항에 따라 국가정보원, 해양수산부, 수사기관 또는 한국인터넷진흥원에 그 사실을 별지 제1호 서식에 따른 침해사고 신고서를 작성하여 통지해야 한다.

② 제1항에 의한 침해사고의 통지에는 다음 각 호의 사항이 포함되어야 한다.

1. 침해사고발생 일시 및 시설
2. 침해사고로 인한 피해내역, 조치현황
3. 그 밖에 신속한 대응·복구를 위하여 필요한 사항

제22조(침해사고 대응조치) ① 관리기관의 업무종사자는 전자적 침해사고의 징후가 있거나 전자적 침해사고의 발생을 인지한 때에는 이를 즉시 정보보호책임자에게 보고해야 한다.

② 정보보호책임자는 소관 주요정보통신기반시설에 대한 중대한 전자적 침해사고의 발생·징후를 보고 받거나 인지한 때에는 이를 국가안보실, 국가정보원, 해양수산부에 즉시 보고해야 한다. 다만, 관리기관의 장은 소관 주요정보통신기반시설의 교란, 마비 또는 파괴가 일어나지 않는 등 경미한 침해사고의 발생·징후는 조치하고 이를 사후 보고할 수 있다.

③ 관리기관의 장은 제1항 및 제2항에 따른 사항을 포함하여 전자적 침해사고 발생에 따른 대응절차 및 방법 등 침해사고 대응체계를 수립해야 한다. 이 경우 별표 1에서 정하는 사항을 고려해야 한다.

제23조(복구조치) ① 관리기관의 장은 소관 주요정보통신기반시설에 대한 침해사고가 발생한 때에는 신속히 해당 주요정보통신기반시설의 복구 및 보호에 필요한 조치를 해야 한다.

② 관리기관의 장은 제1항의 복구조치를 위하여 필요한 조직, 자원,

외부기관과의 협력 등을 포함하는 복구지원체계를 구축해야 한다.

③ 관리기관의 장은 제1항 및 제2항의 내용을 포함하여 전자적 침해 사고가 발생한 시설에 대한 복구절차 및 방법에 관하여 필요한 사항을 정해야 한다. 이 경우 별표 2에서 정하는 사항을 고려해야 한다.

제24조(대응·복구훈련의 실시) ① 관리기관의 장은 업무종사자가 제22조제3항 및 제23조제3항에 따른 침해사고 대응·복구에 관한 절차 및 방법을 정확하고 자세하게 알 수 있도록 필요한 훈련을 정기적으로 실시해야 한다. 이 경우 관리기관의 장이 필요하다고 인정하는 때에는 다른 관리기관과 공동으로 훈련을 실시할 수 있다.

② 관리기관의 장은 대응·복구훈련을 실시한 결과 필요한 경우, 해당되는 대응·복구 절차 및 방법을 수정·보완해야 한다.

제25조(재난 방지대책) ① 관리기관의 장은 인위적 또는 자연적인 원인으로 인한 재해·재난 발생 시에도 주요정보통신기반시설의 중단을 최소화할 수 있도록 백업관리 및 복구 방안 등 종합적인 재난 방지대책을 수립·시행해야 한다.

② 관리기관의 장은 연 1회 이상 정기적인 백업·복구 훈련을 실시하여 제1항에 따른 재난 방지대책의 실효성을 검토하고 미비점을 개선·보완해야 한다.

제26조(외부 용역사업 보안관리) ① 관리기관의 장은 주요정보통신기반시설 관련 정보화사업 및 보안컨설팅 수행 등 외부 용역사업 계약시 보안서약서를 제출하게 하고, 다음 각 호의 사항을 계약서에 구체

적으로 밝혀야 한다.

1. 중요 정보 취급에 대한 비밀 유지 서약
2. 외주 업무종사자가 준수해야 할 보안준수 사항 및 위반 시 손해배상 책임
3. 정보시스템 접근 권한에 대한 승인 절차 준수
4. 보안관리에 대한 감사 권한 등

② 관리기관의 장은 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」과 해양수산부장관이 배포한 「용역업체 보안관리 가이드라인」에 따른 보안 준수사항을 이행했는지 정기 또는 수시로 점검(불시 점검을 포함한다)하고 미비점을 발견한 경우 용역업체로 하여금 시정 조치하도록 해야 한다.

제27조(재검토기한) 장관은 「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 이 훈령에 대하여 2027년 1월 1일을 기준으로 매 3년이 되는 시점(매 3년째의 12월 31일까지를 말한다)마다 그 타당성을 검토하여 개선 등의 조치를 해야 한다.

부 칙

이 훈령은 발령한 날부터 시행한다.

[별표 1] 침해사고 대응체계 수립 시 고려사항

구 분	주요 고려 사항
침해사고 대응·복구 절차 및 방법	○ 침해사고에 대한 복구 절차 및 방법 수립 시 고려 사항 - 침해사고의 정의 및 범위 - 긴급연락체계 구축 - 침해사고 발생 시 대응 요령 및 절차 - 침해사고 복구조직 구성 - 침해사고 복구 장비 및 자원 조달 - 침해사고 대응 및 복구 훈련 실시 사항
침해사고 보고	○ 침해사고 보고 시 고려 사항 - 침해 날짜와 시간 - 침해 사고 보고자 및 보고 일시 - 침해 사고 내용 - 침해 사고 대응 내역
침해사고 발생 시 응급조치	○ 침해사고 발생 후 응급조치 시 고려사항 - 손상된 시스템은 동작을 즉시 정지 - 내부망의 외부 접속을 즉시 차단 - 긴급복구가 즉시 수행되어야 하는 곳은 정보보호전문가에 의한 침입탐지 및 복구
침해사고 복구	○ 침해사고 복구 시 고려사항 - 사고원인의 분석 및 정의 - 필요한 경우, 재발을 방지하기 위한 대책의 수립 및 시행 - 정보자원 및 시스템 백업을 통한 시스템 재구축 방법 - 시스템 및 정보통신망에 대한 취약점 제거

[별표 2] 침해사고 예방조치 시 고려사항

가. 관리·운영 측면의 고려사항

구 분	주요 고려 사항
관리·운영 절차	○ 관리·운영절차의 수립 시 고려사항 - 시스템 문제발생 시 재동작 및 복구 절차 - 시스템 모니터링 방안 - 중요 산출물에 대한 관리 방안 - 업무수행 시 발생될 예외사항 및 오류사항 처리 방안 - 정보처리 및 취급 절차
제한구역 설정 및 보호	○ 제한구역 설정 시 고려 사항 - 보호대상 설정 - 특히 중요한 시설이나 장비는 제한구역으로 설정 - 출입 통제 방안 - 반출입 물품에 대한 기록 유지 - 정전대비 별도의 전원 공급 시설
장비·시설의 도입 및 설치	○ 시스템 구입 및 설치 시 일반적 고려 사항 - 현재 시스템의 성능과 가용능력의 한계에 대한 분석 - 시스템의 기능적, 운용적 요구사항 정의 및 시기의 예측 - 기존 시스템과의 적합성 확보 - 정보보호 시스템의 설치시는 보호지침과의 부합성 및 설치 필요성에 대하여 검증 - 정기적인 점검 및 안전성에 대한 재검토 ○ 정보보호시스템 도입 및 설치·운영 시 고려 사항 - 요구사항 파악 및 도입·설치의 목적 - 성능 및 도입·설치의 타당성에 대한 검토 - 관리의 편의성 및 로그관리의 편의성 - 정보보호시스템에 대한 로그 감시 기능
변경관리 절차	○ 장비, 소프트웨어, 절차들의 변경사항에 대한 관리 책임 및 절차 수립 시 고려사항 - 주요 변경사항 및 변경대상에 관한 정의·기록 유지 - 변경 실패에 따른 복구나 폐기에 대한 책임 정의 절차 - 변경에 대한 잠정적인 영향 평가 - 요구된 변경사항에 대한 승인절차 - 모든 관련자에게 변경사항에 대한 공지 및 교육

구 분	주요 고려 사항
로그 관리	○ 운영자 로그관리방안 수립 시 고려사항 - 시스템 시작, 종료시간, 사용자 인증실패, 접속 시도, 시스템 에러 및 수정 내용 등에 대한 로그 유지 - 로그 기록 방법, 대상, 보존 기간, 백업 등 - 주기적 로그 점검 및 방법 - 접근기록에 대한 정기적 분석 및 불법시도에 대한 조치 방법 - 보안 로그 기록 점검사항에 대한 주기적 보고 ○ 정보보호시스템의 로그 기록 시 필수 고려사항 - 성공적이거나 거부된 접속 - 정보보호시스템 구성요소로부터의 에러 메시지 - 다중 접근 시도 및 불안한 포트로의 접근 - 로그를 저장할 메모리 - 기록이 멈추게 되지 않도록 사전 대책 마련
장애 관리	○ 장애관리 시 고려사항 - 장애의 감지 및 복구를 위해 운영상황 감시 기능 설정 - 장애관리 보고 절차 수립 - 전체시스템에 대한 피해 최소화를 위해 장애차단 및 장애복구 기능 설정 - 장애처리 후 로그에 대한 재점검으로 장애의 완전 복구상태 확인
저장매체 관리	○ 테이프, 디스켓, 출력보고서 등의 저장매체 관리 시 고려 사항 - 저장매체에 대한 목록관리, 분류, 접근통제, 보관 장소, 보관기간, 보관절차 등 수립 - 저장매체에 대한 복사, 변경, 배포, 폐기 방안 - 저장매체 정보저장, 취급 및 전달 절차 수립 - 저장매체 사용에 대한 허가, 점검 수립 및 기록유지 - 저장매체 저장 내용 삭제·폐기 절차
악의적 소프트웨어 관리	○ 컴퓨터바이러스 등 악의적 소프트웨어로부터의 보호를 위한 통제·탐지 조치 시 고려 사항 - 사용자에게 바이러스의 위험성에 대한 인식 필요 - 비인가 및 불법 소프트웨어 사용금지 - 알려진 바이러스 백신프로그램 사용 - 지속적인 바이러스 백신프로그램 업데이트 및 검사 - 검증되지 않은 저장매체는 사용 전에 검사 - 외부 네트워크나 매체로부터 파일 또는 소프트웨어 다운로드 시 대책 마련

나. 기술적 측면에서의 고려사항

구 분	주요 고려 사항
백 업	○ 시스템, 데이터, DB 등 정보자산에 대한 백업조치 시 고려 사항 - 정보자산에 대한 장애 대비 백업 및 복구 절차 규정 - 데이터 중요도에 따른 백업 대상, 백업 방식, 백업주기, 백업기준 등 설정 - 자연재해로부터 보호받을 수 있는 안전한 장소에 대한 지정 - 주기적으로 백업 받은 데이터에 대한 복구 테스트 실시 - 중요정보에 대하여는 제3의 장소 등 물리적으로 분리된 곳에 백업데이터 보관
사용자 관리	○ 사용자 계정 관리 시 고려 사항 - 시스템 접근에 대한 공식적인 사용자 등록 및 해지 절차 수립 - 주기적으로 인가된 사용자 여부 및 접근권한 점검 - 사용자의 공식적인 로그를 보관 - 동일사용자 계정의 다른 사용자 계정 재발급 방지 - 시스템 관리자가 일반 업무 시 일반 사용자 계정 사용
패스워드 관리	○ 패스워드 관리 시 고려사항 - 책임 추적성을 위해 패스워드 할당 - 패스워드의 안전한 보관 - 패스워드의 노출가능성이 있으면 즉시 변경 - 패스워드 설정 시 기피해야 할 요건 . 특정 달, 요일, 머리글자, 주민등록번호, 자동차번호 . 기관명, 전화번호 또는 비슷한 숫자 그룹 . 2개 이상의 연관된 신원확인 가능 문자, 숫자, 영문 알파벳 그룹 - 주기적으로 패스워드를 변경, 지난 패스워드 사용금지 - 특별권한이 부여된 ID의 패스워드는 정기적으로 점검 - 첫 로그인 시 임시 패스워드는 변경 - 비밀번호입력 오류 횟수의 제한
네트워크 접근 통제	○ 네트워크 접근 통제 시 고려 사항 - 네트워크로 접근하는 사용자에 대한 인가 절차 - 원격접속 사용자 인가 절차 - 비인가된 접근을 막기 위해 서비스 경로의 제한 및 분리 - 관계기관 등과 네트워크 공유 시에는 물리적 또는 논리적으로 분리 - 원격 장비의 관리를 위한 책임 및 절차를 수립 - 개발업무 네트워크와 다른 업무용 네트워크와의 분리 운영 - 인증, 암호 활용을 통한 원격 접속 사용자에 대한 접근통제 - 네트워크를 통해 시스템 운영 시 시스템 관리는 원칙적으로 내부 특정 단말로 제한

[별지 제1호 서식] 침해사고 신고서

기 본 정 보			
기 관 명		부 서	
성 명		직 위	
전자우편			
연 락 처	전화:	H.P:	Fax:
사 고 내 용			
사고 일시	년 월 일	피해IP 주소	
	시 분		
피해시스템 용도	* 뒷장의 시스템 분류 목록 입력	운영체제	☐ 윈도우 ☐ 유닉스 ☐ 네트워크장비
			상세버전정보:
사고 유형	* 뒷장의 사고 유형 기호입력	피해범위	00 대 * 피해시스템이 여러대인 경우 피해숫자 기입
사고 내용			
조 치 사 항			
공격자 정보			
피해 현황			
긴급조치 실시사항			
관련보안제품 운영현황			
그 밖에 사고 관련 내용을 구체적으로 서술			

※ 해양수산부⇒국가정보원(Fax 02-3432-0463 또는 reply@ncsc.go.kr)

※ 소속·공공기관⇒해양수산부(Fax 051-773-6389 또는 ocsc@korea.kr)

1. 시스템 분류 목록

기호	시스템 분류	설 명
가	웹서버	기관의 홈페이지 운영 및 웹서비스를 제공하는 서버
나	전자우편서버	전자우편 송수신을 위해 운영하는 서버
다	DB/업무서버	홈페이지 및 업무지원을 위한 데이터베이스 서버
라	개발/임시서버	개발 및 운영 테스트를 위하여 사용하는 임시 서버
마	통신전송장비	라우터, 스위치 등 통신전송장비 전부
바	보안장비	방화벽, IDS, VPN 및 백신서버 등 정보보안제품 전부
사	개인/업무PC	기관 내 사용자의 PC
아	교육/임시PC	교육장 또는 공용 작업을 위해 여러 명이 사용하는 PC
자	그 밖의 시스템	위의 시스템 용도에 없는 경우 서술식으로 기술

2. 사고 유형 목록

기호	사고 유형	설 명
A	경유지 악용	他기관으로부터 해킹시도 항의를 받았거나, 시스템 점검 중 해킹흔적 또는 해킹 툴이 설치되어 他시스템에 접속한 기록이 발견되었을 경우
B	자료훼손 및 유출	내부 시스템의 자료가 변조가 되었거나 대량의 데이터가 외부로 무단 송신된 흔적이 발견되었을 경우
C	악성코드 감염	기관 내의 서버 PC에서 악성코드가 발견되었을 경우
D	홈페이지 변조	기관의 홈페이지가 변조되었을 경우
E	홈페이지 접속 불가능	기관의 홈페이지 서버 또는 네트워크 이상으로 인해 홈페이지 접속이 불가능할 경우
F	서비스거부공격 피해	불특정 다수의 IP로부터 접속 시도 또는 대량 트래픽이 한꺼번에 유입될 경우
G	시스템 파괴	내부 시스템의 자료가 삭제되어 사용이 불가능한 경우
H	그 밖의 사고	위의 사고유형에 포함되지 않을 경우 서술식으로 기술